

Scenario:

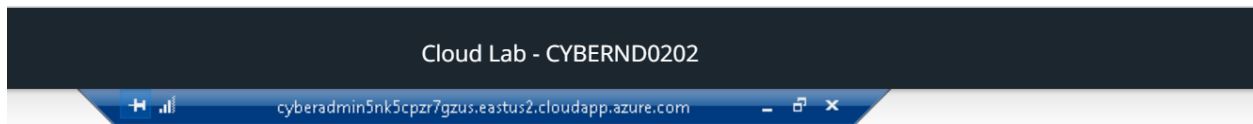
Douglas Financials Inc (DFI from here forward) has experienced successful growth and as a result is ready to add a Security Analyst position. Previously Information Security responsibilities fell on our System Administration team. Due to compliance and the growth of DFI we are happy to bring you on as our first InfoSec employee! Once you are settled in and finished orientation we have your first 2-Weeks assignments ready.

Week One:

1. Connect:

All of the subsequent steps will take place in the DFI environment. You will need to RDP into the Windows 10 workstation and use it to connect with the Windows and Linux servers provided using RDP and SSH (via PowerShell) respectively.

[Please Provide Screenshots of the RDP and SSH here as evidence that you completed this step.]



```
cyberadmin@dfi-app-001:~  
Windows PowerShell  
Copyright (C) Microsoft Corporation. All rights reserved.  
  
Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows  
  
PS C:\Users\ANM\j> ssh cyberadmin@172.177.247.45  
cyberadmin@172.177.247.45's password:  
Last failed login: Thu Dec 15 14:24:38 UTC 2022 from 95.184.76.205 on ssh:notty  
There was 1 failed login attempt since the last successful login.  
Last login: Thu Jul 15 10:41:51 2021 from 206.85.160.135  
cyberadmin@dfi-app-001 ~$
```

Cyberadmin username	cyberadmin	
Cyberadmin password	udacitylearning.1!!	
Command to Connect to cyberadmin VM	ssh cyberadmin@172.177.247.45	

2. Security Analysis:

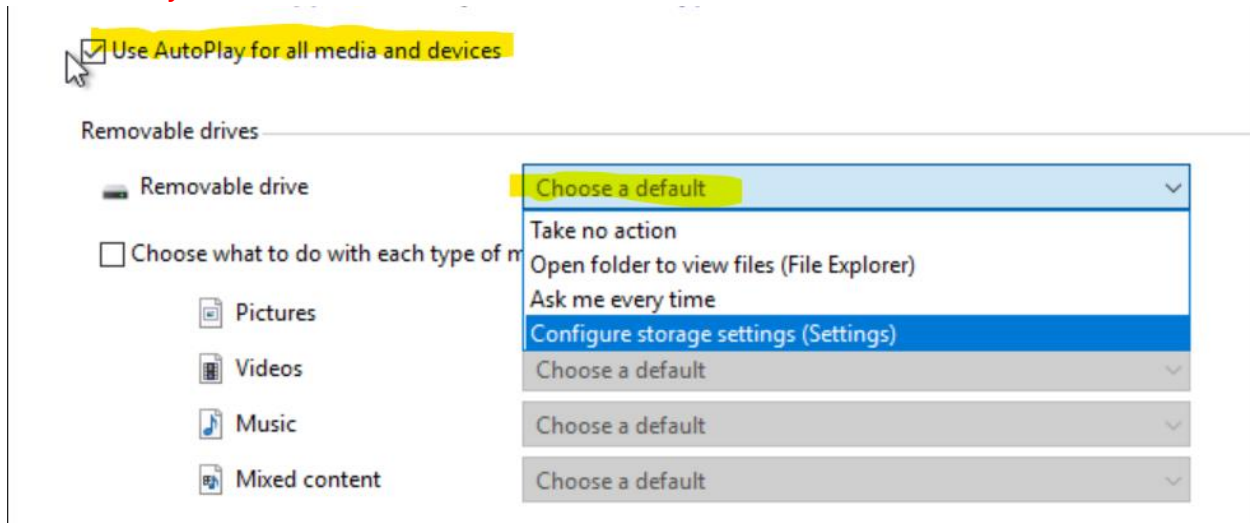
DFI has an excellent SysAdmin team, but they have been focused on system reliability and scaling to meet our growing needs and as a result, security may not be as tight as we'd like. Your first assignment is to familiarize yourself with our file and application servers.

Please perform an analysis of the Windows server and provide a written report detailing any security configuration issues found and a brief explanation and justification of the changes you recommend. DFI is a PCI compliant organization and will likely be Sarbanes-Oxley in the near future.

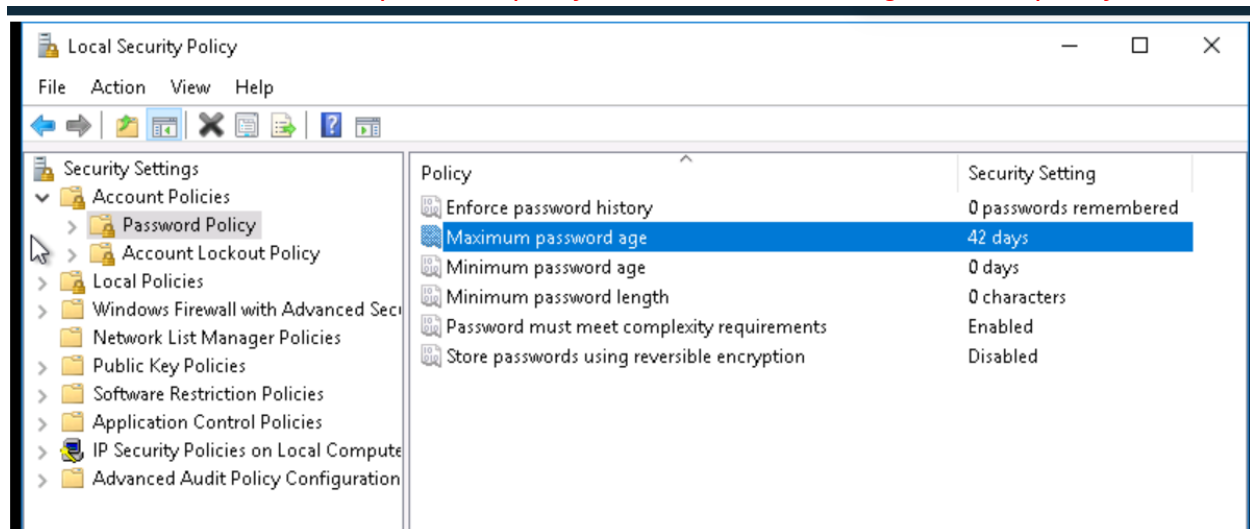
Use NIST, Microsoft, Defense-in-Depth, Principle of Least Privilege and other resources to determine the changes that should be made. Note changes can be to **add/remove/change** services, permissions and other settings. [Defense-in-Depth documentation](#). [NIST 800-123](#) (other NIST documents could also apply.)

[Place your security analysis here]

1. Removable hard drives are not allowed to start automatically and must be prompted by the user.

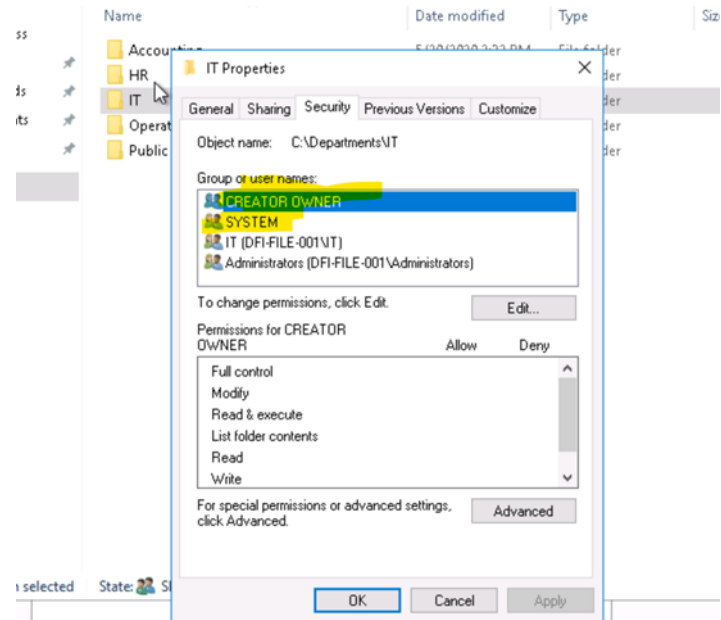
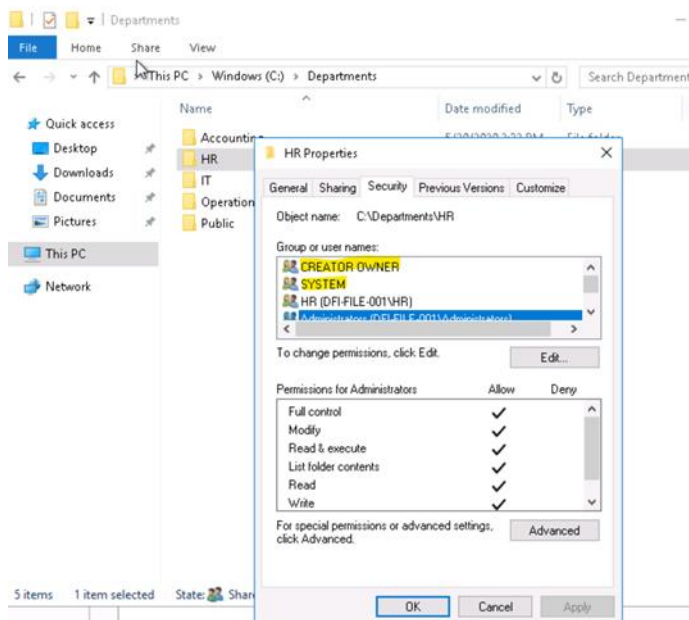


2. You must have a password policy such as a maximum age and complexity.



3. Set file permissions.

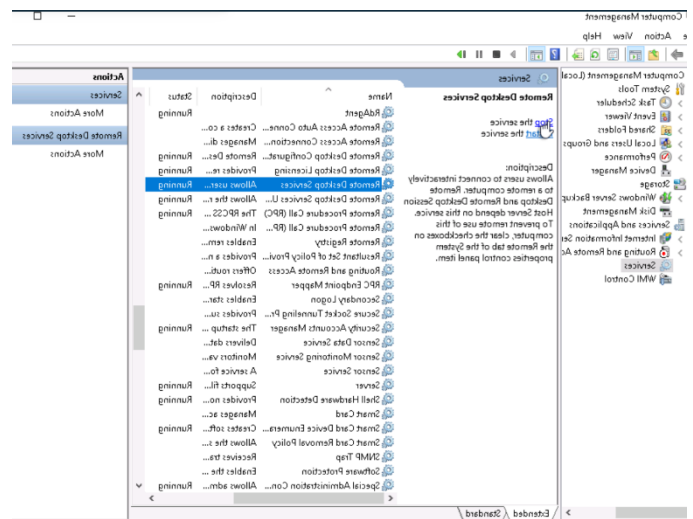
To apply the principle of least privilege, the System and Creator owner groups should be removed because they do not have access to the HR folder and similarly to the IT folder.



4. Services.

Services such as Remote Desktop and Multipoint must be disabled.

Name	Description	Status	Services
Microsoft App-V Client	Manages A...		More
Microsoft iSCSI Initiator Ser...	Manages In...		More
Microsoft Key Distribution S...	This service ...		
Microsoft Passport	Provides pr...		
Microsoft Passport Container	Manages lo...		
Microsoft Software Shadow...	Manages so...		
Microsoft Storage Spaces S...	Host service...	Running	
Multipoint Repair Service	Automatica...	Running	
Multipoint Service	Provides loc...	Running	
Net.Tcp Listener Adapter	Receives act...	Running	
Net.Tcp Port Sharing Service	Provides abi...	Running	
NetLogon	Maintains a		



3. Firewall Rules:

DFI does not have a dedicated networking department just yet, once again these tasks normally fall under the SysAdmin group. Now that we have you as a security professional, you'll take over the creation of our firewall rules. We recently entered into a new partnership and require new IP connections.

Using Cisco syntax, create the text of a firewall rule allowing a new DFI partner WBC International, access to DFI-File-001 access via port tcp-9082.

The partner's IP is 21.19.241.63 and DFI-File-001's IP is 172.21.30.44.

For this exercise assume the two IP objects **have not** been created in the firewall. **Note*** Use *DFI-Ingress* as the interface for the rule. For documentation purposes, please explain the syntax for non-technical management on the change control board that meets weekly.

[Place your firewall rules and explanation here]

Access-list DFI-Ingress extended permit tcp host 21.19.241.63 host 172.21.30.44 eq 9082

- Access- list controls traffic.
- DFI-Ingress is internal interface.
- Extended permit is flexibility in matching traffic.
- Tcp is protocol being used.
- Source is IP address that will be allowed to access.
- Destination is IP address of our database server.
- eq means equal to, we are processing the port.

4. VPN Encryption Recommendation:

DFI is creating a payroll processing partnership with Payroll-USA, this will involve creating a VPN connection between the two. Research, recommend and justify an encryption solution for the connection that is using the latest available encryption for Cisco. Use the Cisco [documentation](#) as a guide.

[Place your VPN Encryption Recommendation here]

AES, It is considered a secure method of encryption due to the length of the encryption key and the lack of a way to crack it yet.

5. IDS Rule:

The System Administrator gave you a heads up that DFI-File-001 with an IP address of 172.21.30.44 has been receiving a high volume of ICMP traffic and is concerned that a DDoS attack is imminent. She has requested an IDS rule for this specific server.

The VoIP Administrator is also concerned that an attacker is attempting to connect to her primary VoIP server which resides at 172.21.30.55 via TFTP. She has requested an IDS rule for this traffic.

For documentation purposes, please explain the syntax for non-technical management on the change control board that meets weekly.

[Place your System Admin rule and explanation here]

alert icmp any any -> 172.21.30.55 any (msg:" ICMP attempt"; sid:1000001)

[Place your VoIP Admin rule and explanation here]

alert udp any any -> 172.21.30.55 69 (msg:" TFTP attempt"; sid:1000003)

alert : alert generated. any : source IP address, saucer port. IP address : destination IP.
Port : destination port. msg : rule options.

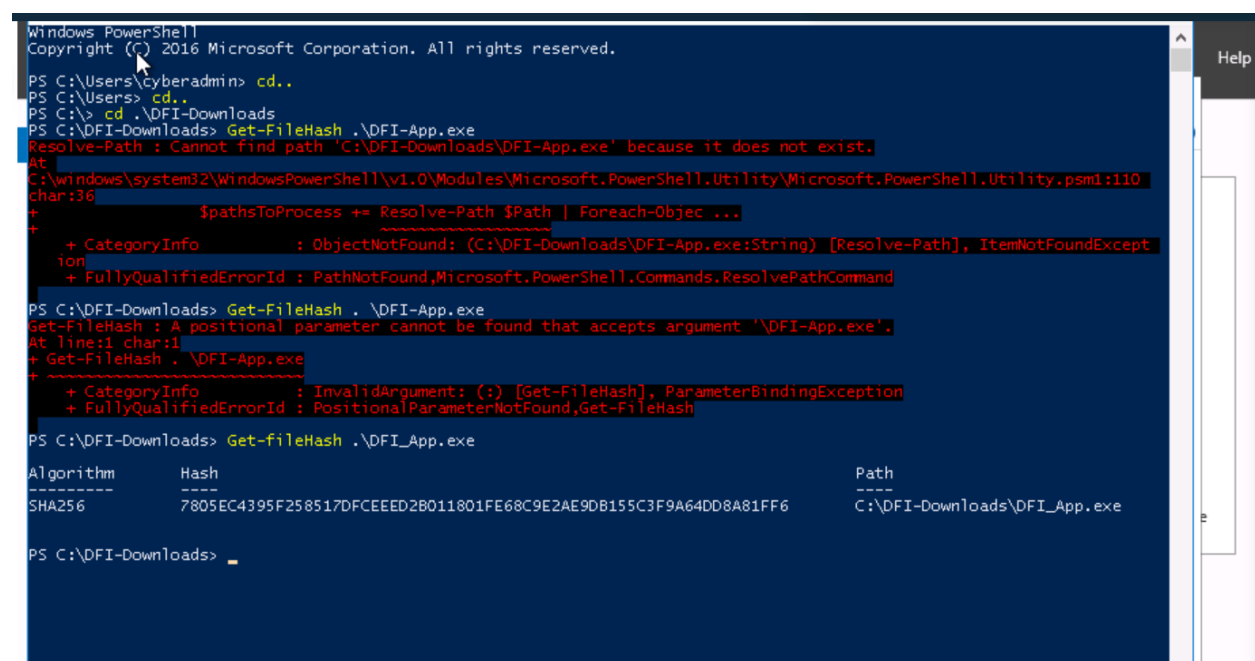
6. File Hash verification:

A software vendor has supplied DFI with a custom application. They have provided the file on their public FTP site and e-mailed you directly a file hash to verify the integrity and authenticity. The hash provided is a SHA256.

Hash: 7805EC4395F258517DFCEEED2B011801FE68C9E2AE9DB155C3F9A64DD8A81FF6

Perform a file hash verification and submit a screenshot of your command and output.
The File is stored on the Windows 2016 Server in C Drive under DFI-Download.

[Place your screenshot verification here]



```
Windows PowerShell
Copyright (C) 2016 Microsoft Corporation. All rights reserved.

PS C:\Users\Cyberadmin> cd..
PS C:\Users> cd..
PS C:\> cd .\DFI-Downloads
PS C:\DFI-Downloads> Get-FileHash .\DFI-App.exe
Resolve-Path : Cannot find path 'C:\DFI-Downloads\DFI-App.exe' because it does not exist.
At
C:\Windows\system32\WindowsPowerShell\v1.0\Modules\Microsoft.PowerShell.Utility\Microsoft.PowerShell.Utility.psml:110
char:36
+ ~~~~~
+ $pathsToProcess += Resolve-Path $Path | Foreach-Object {
+ ~~~~~
+   + CategoryInfo          : ObjectNotFound: (C:\DFI-Downloads\DFI-App.exe:String) [Resolve-Path], ItemNotFoundExcept
+   ~~~~~
+   + FullyQualifiedErrorId : PathNotFound,Microsoft.PowerShell.Commands.ResolvePathCommand
PS C:\DFI-Downloads> Get-FileHash . \DFI-App.exe
Get-FileHash : A positional parameter cannot be found that accepts argument '\DFI-App.exe'.
At line:1 char:1
+ Get-FileHash . \DFI-App.exe
+ ~~~~~
+   + CategoryInfo          : InvalidArgument: (:) [Get-FileHash], ParameterBindingException
+   + FullyQualifiedErrorId : PositionalParameterNotFound,Get-FileHash
PS C:\DFI-Downloads> Get-fileHash .\DFI_App.exe

Algorithm      Hash
-----
SHA256         7805EC4395F258517DFCEEED2B011801FE68C9E2AE9DB155C3F9A64DD8A81FF6
Path
-----
C:\DFI-Downloads\DFI_App.exe

PS C:\DFI-Downloads> _
```

Week Two:

Now that you've performed a light audit and crafted Firewall and IDS Signatures we're ready for you to make some additional recommendations to tighten up our security.

7. Automation:

The IT Manager has tasked you with some introductory research on areas that could be improved via automation.

Research and recommend products, technologies and areas within DFI that could be improved via automation.

Recommended areas are:

- SOAR products and specifically what could be done with them
- Automation of mitigation actions for IDS and firewall alerts.
- Feel free to elaborate on other areas that could be improved.

Complete the chart below including the area/technology within DFI and a proposed solution, with a minimum of 3 areas. Provide a brief explanation for your choices

DFI Area/Technology	Solution	Justification for Recommendation
SOAR	Fortinet	focuses on tool consolidation, security orchestration and automation, case management, and incident response.
Security	Event log	It allows users to view event logs on the device to report events such as failure to start a component or complete procedures, but hackers use it to disable these events and steal data, so it is important to monitor them
SOAR	Swimlane	collect alerts from a wide range of sources as well as automate manual incident response processes and operational workflows—helping reduce the burden on SOC analysts.

IDS	Fail2ban	intrusion prevention software framework. it is designed to prevent against brute-force attacks. It is able to run on POSIX systems that have an interface to a packet-control system or firewall installed locally, such as iptables or TCP Wrapper.

8. Logging RDP Attempts:

The IT Manager suspects that someone has been attempting to login to DFI-File-001 via RDP.

Prepare a report that lists unsuccessful attempts in connecting over the last 24-hours. Using Powershell or Eventviewer, search the Windows Security Log for Event 4625. Export to CSV.

For your deliverable, open the CSV with notepad and take a screenshot from your personal computer for your explanation. Please also include this file in your submission. Then in your report below explain your findings, recommendations and justifications to the IT Manager.

[Place IT Manager Report Here]

ملف تحرير عرض

Keywords, Date and Time, Source, Event ID, Task Category

.Microsoft-Windows-Security-Auditing, 4625, Logon, "An account failed to log on, Audit Failure, 16/05/44 06:23:44

:Subject

:Security ID

LAPTOP-3ERSK9PM

:Account Name

مبعاد

:Account Domain

LAPTOP-3ERSK9PM

:Logon ID

0x1770A3

:Logon Type

2

:Account For Which Logon Failed

:Security ID

NULL SID

:Account Name

مبعاد

:Account Domain

LAPTOP-3ERSK9PM

:Failure Information

:Failure Reason

.Unknown user name or bad password

:Status

0xC000006D

:Sub Status

0xC000006A

:Process Information

:Caller Process ID

0x18f4

:Caller Process Name

rogram Files (x86)\Microsoft\EdgeWebView\Application\90.0.818.66\msedgewebview2.exe

:Network Information

:Workstation Name

LAPTOP-3ERSK9PM

:Source Network Address

-

:Source Port

-

This event is generated when the login request fails as the user has either entered the wrong username or password. The subject fields indicate the account on the local system that requested the Logon: name, id, and domain. The Logon Type field indicates the required login type including ID, name and domain. The network information fields indicate the source of the remote Logon request. I recommend refusing to accept a login on port 4625.

9. Windows Updates:

Using [NIST 800-40r3](#) and [Microsoft Security Update Guide](#), analyze the windows servers and provide your answers in the table below of available updates (KB and CVE) that should be installed as well as any updates that can be safely ignored for DFI's purpose. To assist, be aware that DFI is concerned with stability and security, any update that is not labeled as a 'critical' or 'security' can be left off.

Justify your recommendations as to why you are making your choices.

Add as many rows or additional columns as you need to the table.

Available Updates	Update/Ignore	Justification
(KB5002286)	Update	This security update resolves a security vulnerability in Microsoft Office Visio remote code execution.
(KB501841)	Update	Addresses an issue that affects some virtual machines. They drop User Datagram Protocol (UDP) packets and address an issue affecting Server Message Block (SMB) multichannel communication. This problem may lead to Stop error 13A or C2.
(KB5002321)	Update	This security update resolves a remote code execution vulnerability in Microsoft SharePoint Server.
(KB5021235)	Ignore	Applications that use ODBC connections may not connect through the Microsoft ODBC SQL Server Driver (sqlsrv32.dll) to access databases. Additionally, you may receive an error from SQL Server.

(KB5005043)	Ignore	Updates that you don't need, such as an update to an issue with displaying some characters and a zoom issue in Microsoft Edge IE.
(KB5019964)	Ignore	Remote desktop connections using domain users may fail to connect.

10. Linux Data Directories:

The IT Manager has requested your help with creating directories on the CentOS server DFI-App-001 (reachable by ssh from the Windows 10 machine. in the DFI subnet.)

- The root directory should be 'Home'

- The first subdirectory should be "Departments" with subdirectories: HR, Accounting, Public, IT and Operations.
- Set owner permissions for the groups IT, HR, Operations and Accounting
- Create the users AmyIT, PamOps, MandyAcct and TimHR in the appropriate groups so that they can read/write/execute in their respective departmental folders.

For documentation purposes, please explain the syntax for non-technical management on the change control board that meets weekly.

[Provide a screenshot(s) of completed tasks and the correctly set permissions here]

[Provide your non-technical syntax explanation for management here]

1. In the syntax, create a directory named Home and move to it using cd command, create another directory named Departments inside it and then create HR, Accounting, Public, IT, Operations.

```

root@dfi-app-001 ~]# mkdir Home
root@dfi-app-001 ~]# cd Home
root@dfi-app-001 Home]# mkdir Departments
root@dfi-app-001 Home]# cd Departments
root@dfi-app-001 Departments]# mkdir HR Accounting Public IT Operations
root@dfi-app-001 Departments]# ls
Accounting HR IT Operations Public

```

2. Using the ls command, all directories will be listed without details, only their names, but ls -l will list directories with details as shown here below

```

[root@dfi-app-001 Departments]# ls -l
total 0
drwxr-xr-x. 2 root Accounting 6 Dec 23 20:50 Accounting
drwxr-xr-x. 2 root HR 6 Dec 23 20:50 HR
drwxr-xr-x. 2 root IT 6 Dec 23 20:50 IT
drwxr-xr-x. 2 root Operations 6 Dec 23 20:50 Operations
drwxr-xr-x. 2 root root 6 Dec 23 20:50 Public
[root@dfi-app-001 Departments]#

```

2. Use sudo su - to issue commands and then add groups using the groupadd command.
3. The group owner's permissions are changed using the chown command.

```

[root@dfi-app-001 ~]# cd Home
[root@dfi-app-001 Home]# cd Departments
[root@dfi-app-001 Departments]# chown :HR HR/
[root@dfi-app-001 Departments]# chown :IT IT/
[root@dfi-app-001 Departments]# chown :Accounting Accounting/
[root@dfi-app-001 Departments]# chown :Operations Operations/

```

4. Finally, in the syntax, use the useradd command to create users and then add them to their respective groups using the usermod command.

```

[root@dfi-app-001 Departments]# useradd AmyIT
[root@dfi-app-001 Departments]# useradd PamOps
[root@dfi-app-001 Departments]# useradd MandyAcct
[root@dfi-app-001 Departments]# useradd TimHR
[root@dfi-app-001 Departments]# usermod -g IT AmyIT
[root@dfi-app-001 Departments]# usermod -g Accounting MandyAcc
usermod: user 'MandyAcc' does not exist
[root@dfi-app-001 Departments]# usermod -g Accounting MandyAcct
[root@dfi-app-001 Departments]# usermod -g HR TimHR
[root@dfi-app-001 Departments]# usermod -g Operations PamOps
[root@dfi-app-001 Departments]#

```

```

root@dfi-app-001:~/Home/Departments
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Install the latest PowerShell for new features and improvements! https://aka.ms/PSWindows

PS C:\Users\0011fj> ssh cyberadmin@20.98.253.46
The authenticity of host '20.98.253.46 (20.98.253.46)' can't be established.
ECDSA key fingerprint is SHA256:Sd5Fgp10nKJzAv00Ltd11MBunt3sVB8fD2joH9BHqug.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '20.98.253.46' (ECDSA) to the list of known hosts.
cyberadmin@20.98.253.46's password:
Permission denied, please try again.
cyberadmin@20.98.253.46's password:
Last failed login: Fri Dec 23 20:43:40 UTC 2022 from 93.169.80.253 on ssh:notty
There was 1 failed login attempt since the last successful login.
Last login: Thu Jul 15 10:41:51 2021 from 206.85.160.135
[cyberadmin@dfi-app-001 ~]$ sudo su -
[sudo] password for cyberadmin:
Last failed login: Tue Jul 13 12:44:19 UTC 2021 from 20.68.192.218 on ssh:notty
There was 1 failed login attempt since the last successful login.
[root@dfi-app-001 ~]# mkdir Home
[root@dfi-app-001 ~]# cd Home
[root@dfi-app-001 Home]# mkdir Departments
[root@dfi-app-001 Home]# cd Departments
[root@dfi-app-001 Departments]# mkdir HR Accounting Public IT Operations
[root@dfi-app-001 Departments]# ls
Accounting HR IT Operations Public
[root@dfi-app-001 Departments]# sudo su -
Last login: Fri Dec 23 20:45:23 UTC 2022 on pts/0
[root@dfi-app-001 ~]# groupadd IT
[root@dfi-app-001 ~]# groupadd Accounting
[root@dfi-app-001 ~]# groupadd HR
[root@dfi-app-001 ~]# groupadd Operations
[root@dfi-app-001 ~]# cd Departments
-bash: cd: Departments: No such file or directory
[root@dfi-app-001 ~]# cd Home
[root@dfi-app-001 Home]# cd Departments
[root@dfi-app-001 Departments]# chown :HR HR/
[root@dfi-app-001 Departments]# chown :IT IT/
[root@dfi-app-001 Departments]# chown :Accounting Accounting/
[root@dfi-app-001 Departments]# chown :Operations Operations/
[root@dfi-app-001 Departments]# chown :Public Public/
chown: invalid group: ':Public'
[root@dfi-app-001 Departments]# ls -l
total 0
drwxr-xr-x. 2 root Accounting 6 Dec 23 20:50 Accounting
drwxr-xr-x. 2 root HR 6 Dec 23 20:50 HR
drwxr-xr-x. 2 root IT 6 Dec 23 20:50 IT
drwxr-xr-x. 2 root Operations 6 Dec 23 20:50 Operations
drwxr-xr-x. 2 root root 6 Dec 23 20:50 Public
[root@dfi-app-001 Departments]# useradd AmyIT
[root@dfi-app-001 Departments]# useradd PamOps
[root@dfi-app-001 Departments]# useradd MandyAcct
[root@dfi-app-001 Departments]# useradd TimHR
[root@dfi-app-001 Departments]# usermod -g IT AmyIT
[root@dfi-app-001 Departments]# usermod -g Accounting MandyAcct
usermod: user 'MandyAcct' does not exist
[root@dfi-app-001 Departments]# usermod -g Accounting MandyAcct
[root@dfi-app-001 Departments]# usermod -g HR TimHR
[root@dfi-app-001 Departments]# usermod -g Operations PamOps

```

11. Firewall Alert Response:

The IT Manager took a look at firewall alerts and was concerned with some traffic she saw, please take a look and provide a mitigation response to the below firewall report. Remember to justify your mitigation strategy.

This file is available from the project resources title: **DFI_FW_Report.xlsx**. Please download and use this file to complete this task.

[Firewall mitigation response and justification goes here]

You report it to AbuseIPDB because this IP address has been reported more than once and has 0% trust and use the block list to block this IP address from connecting again.


AbuseIPDB

[Home](#)
[Report IP](#)
[Bulk Reporter](#)
[Pricing](#)
[About](#)
[FAQ](#)
[Documentation](#)
[Statistics](#)
[IP Tools](#)
[Contact](#)
[LOGIN](#)
[SIGN UP](#)

Report IP Address **192.34.57.157**:

[VIEW REPORT HISTORY FOR 192.34.57.157](#)
[WHOIS 192.34.57.157](#)

To use the report and report-bulk endpoints, your account must be approved. [Request reporting privilege.](#)

IP Address (ex. 8.8.8.8)

192.34.57.157

Categories (at least one is required)

☐ DNS Compromise	☐ DDoS Attack	☐ Email Spam	☒ Brute-Force
☐ DNS Poisoning	☐ Open Proxy	☐ Port Scan	☐ Bad Web Bot
☐ Fraud Orders	☐ Web Spam	☐ Spoofing	☐ Exploited Host
☐ Web App Attack	☐ FTP Brute-Force	☐ Fraud VoIP	☐ Hacking
☐ SSH	☐ Ping of Death	☐ Blog Spam	☐ SQL Injection
☐ IoT Targeted	☐ Phishing	☐ VPN IP	

Comment Characters left: 1024/1024

Comment (server log snippets, abuse details, etc)

[REPORT IP ADDRESS](#) Please abide by our [reporting policy](#).

12. Status Report and where to go from here:

As your first two weeks wind down, the IT Manager, HR Manager as well as other management are interested in your experience. With your position being the first dedicated Information Security role, they would like a 'big picture' view of what you've done as well as the security posture of DFI.

Similar to Defense-in-Depth, an organization has multiple layers of security from the edge of their web presence all the way to permissions on a file.

In your own words explain the work you've done, the recommendations made and how DFI should proceed from a security standpoint. This is your opportunity to provide a thoughtful analysis that shows your understanding of Cyber Security and how all of the tasks you've performed contribute to the security of DFI. As this will be reviewed by non-technical management please keep the technical jargon to a minimum.

[Provide your Status Report Here]

- Cybersecurity is computer security and aims to protect systems, networks and programs against digital attacks such as: social engineering, phishing, ransomware.

1. Ransomware - a malicious program that restricts access to the computer system it infects and demands the payment of a ransom.
2. Social Engineering - Techniques used to deceive people into doing something or checking confidential information.
3. Phishing - An attempt to obtain sensitive information such as usernames and passwords for malicious reasons.
 - The security model consists of: Prevention, detection, response.
 - Defense in depth is an information assurance strategy that provides multiple and iterative defensive measures in the event of a security control failure or an exploit of a security vulnerability consisting of physical controls - security measures that prevent physical access to systems. Technical Controls - Security measures protect network systems using specialized hardware or software, such as a hardware firewall or antivirus software. Administrative controls - Policies or procedures directed at an organization's personnel, for example, directing users to classify sensitive information as "confidential".

I analyzed the Windows server and it showed me many things that we should not allow, such as file permissions and running services, so I imposed the principle of least privilege and disabled those services, and I also wrote the firewall rule and IDS rules to protect the network from unwanted connections and DDoS And I recommended the type of VPN encryption, then I checked the hash file to verify its integrity and authenticity, and the result was that the file hash was the same, then I recommended products and technologies optimized via automation to use in DFI, and after that I prepared a report that lists unsuccessful connection attempts and also searched for Windows Server updates 2016 that should be updated or ignored and justified after that I created a directory on the CentOS server and finally, I provided a response to mitigate the firewall.

13. File Encryption:

As your final task, assemble all of the deliverables you have created in Steps 1-12 and encrypt them using 7zip with a strong password.

When you submit the file you must also include your password as a note to the reviewer at Udacity or they will not be able to review your project.